

Безопасность загрузки ОС

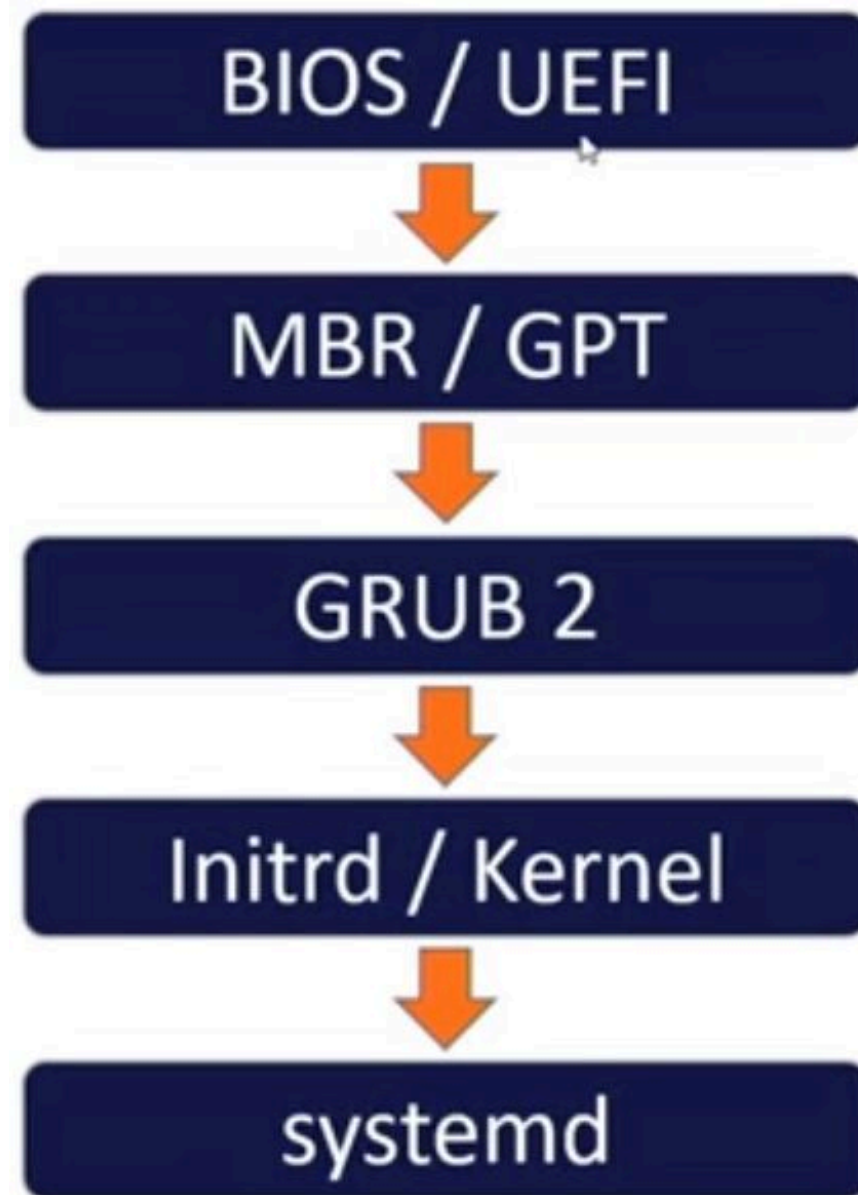
Лабораторный практикум. ВМ: Debian 13 (Trixie)

Темы: GRUB2 · UEFI Secure Boot · LUKS · TPM 2.0 · UKI

Практикум по информационной безопасности · 2026

Путь загрузки ОС

- **UEFI/BIOS** — инициализация оборудования, передача управления загрузчику (раздел ESP)
- **Загрузчик** — GRUB2 / shim: выбор и загрузка ядра и initramfs
- **Ядро + initramfs** — драйверы дисков, расшифровка и монтирование корневой ФС
- **systemd** — старт сервисов и пользовательской сессии
- Каждый этап — точка, в которой может вмешаться атакующий



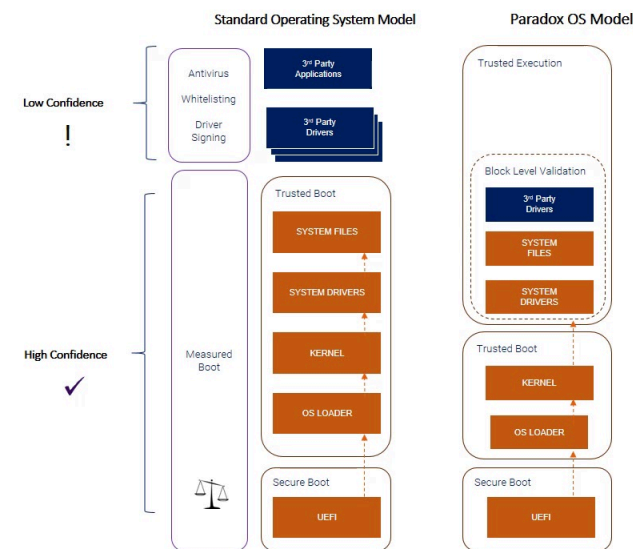
Угрозы процессу загрузки

- Физический доступ и «evil maid»: правка параметров ядра в загрузчике (`init=/bin/bash`)
- Подмена загрузчика или ядра: буткиты и руткиты ранней стадии
- Кража диска / образа VM: чтение данных в обход ОС
- Загрузка неподписанных модулей ядра: обход контроля целостности
- Уязвимости самих загрузчиков: BootHole (CVE-2020-10713, GRUB2)



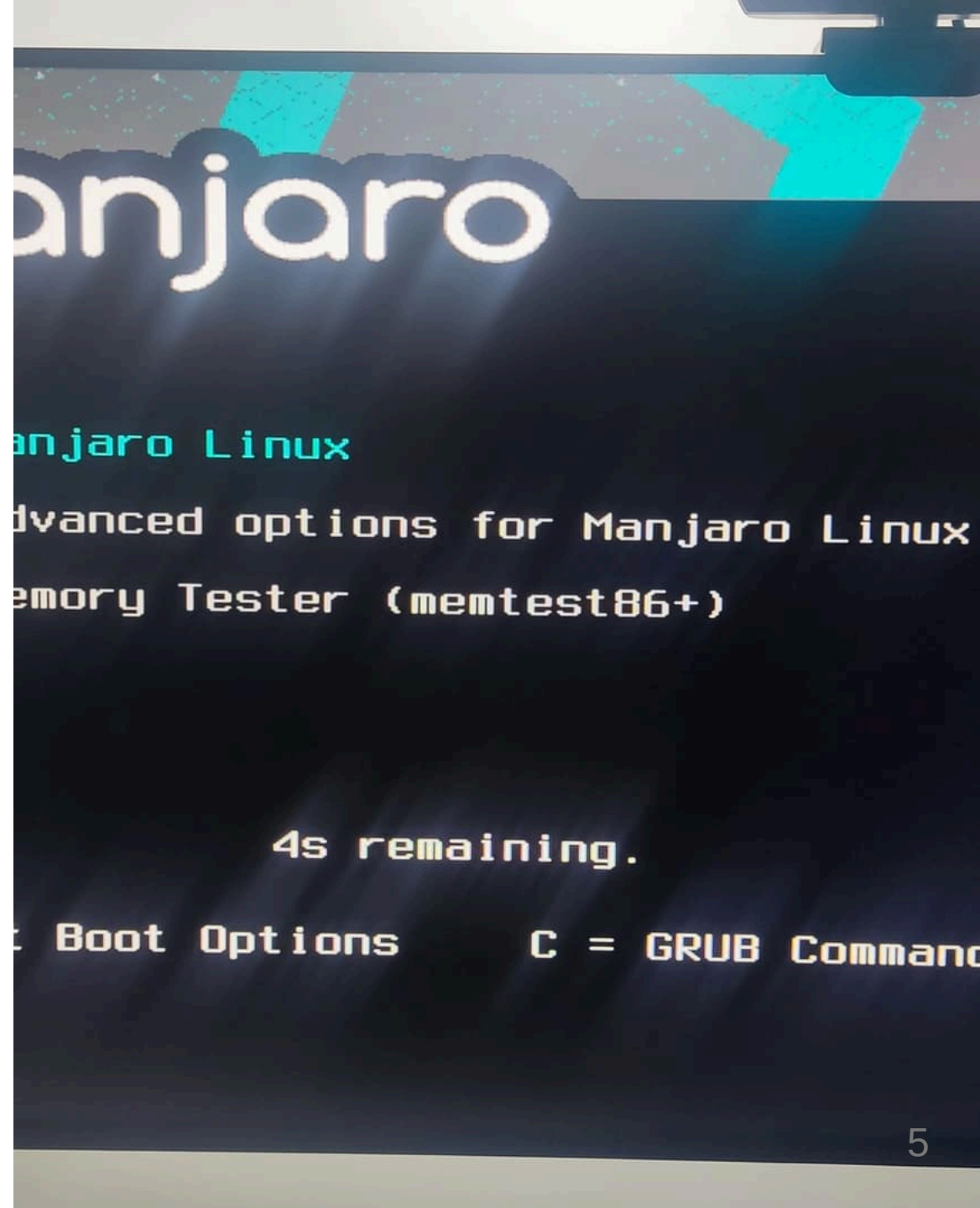
Защита: эшелонированная оборона

- **Secure Boot** — к выполнению допускаются только подписанные компоненты
- **Пароль загрузчика** — защита конфигурации и параметров ядра от правки
- **LUKS** — шифрование диска до момента расшифровки корня
- **TPM 2.0 / measured boot** — измерение состояния загрузки (PCR), «опечатывание» ключей



Работа 1. Атака на GRUB2

- Меню GRUB по умолчанию позволяет нажать **e** — редактирование пункта
- В строке `linux` к параметрам (`ro` `quiet`) дописывается `init=/bin/bash`
- Результат: root-оболочка **без аутентификации** (`uid=0`)
- Тот же класс атак: `rw` `init=/bin/sh`, `single`, загрузка `recovery`-режима



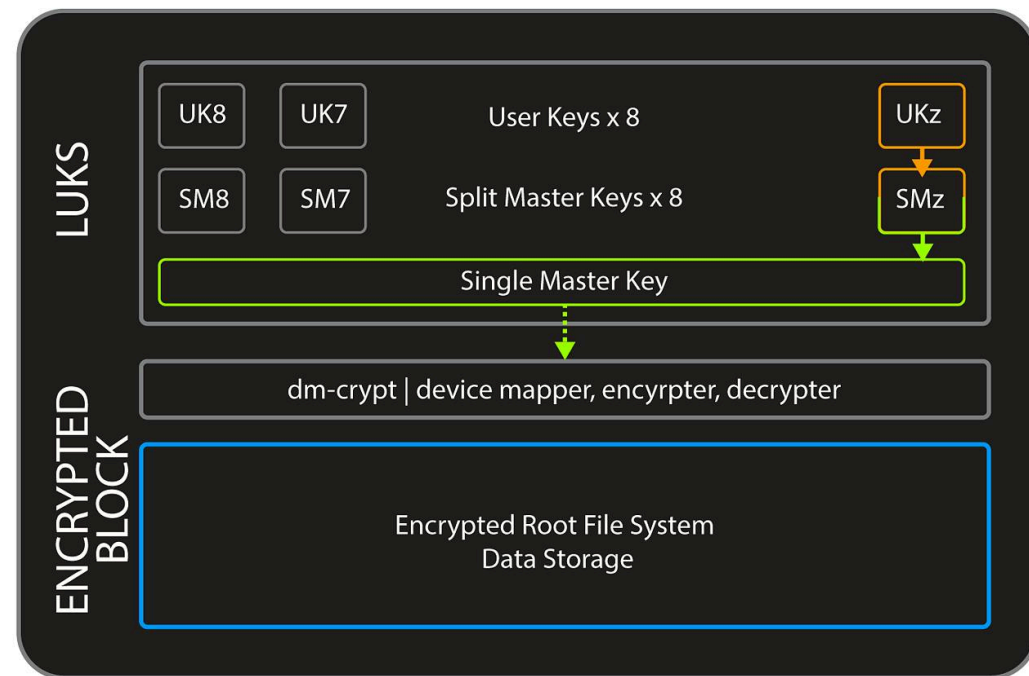
Работа 1. Защита GRUB2

```
grub-mkpasswd-pbkdf2 # хеш пароля PBKDF2-SHA512
# /etc/grub.d/40_custom:
set superusers="admin"
password_pbkdf2 admin grub.pbkdf2.sha512.10000.XXXX
# в 10_linux: menuentry --unrestricted ... (загрузка без пароля)
sudo update-grub
```

- Без пароля остаётся только штатная загрузка (`--unrestricted`)
- Редактирование пунктов и консоль GRUB — только по логину/паролю

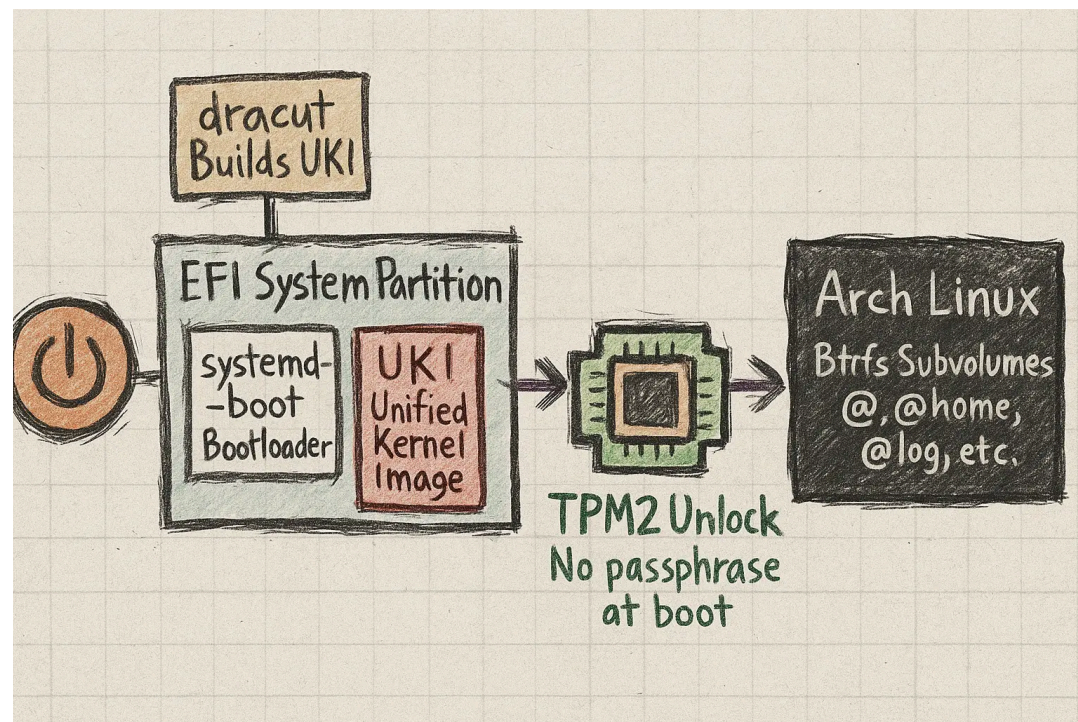
Работа 2. LUKS: шифрование диска

- Заголовок LUKS: слоты ключей (пароль / keyfile / TPM) защищают master-key
- initramfs запрашивает пароль **до** монтирования корневой ФС
- Кража образа VM или диска без ключа бессмысленна
- Слабое место: незашифрованные `/boot` и `initramfs` → нужны Secure Boot / TPM



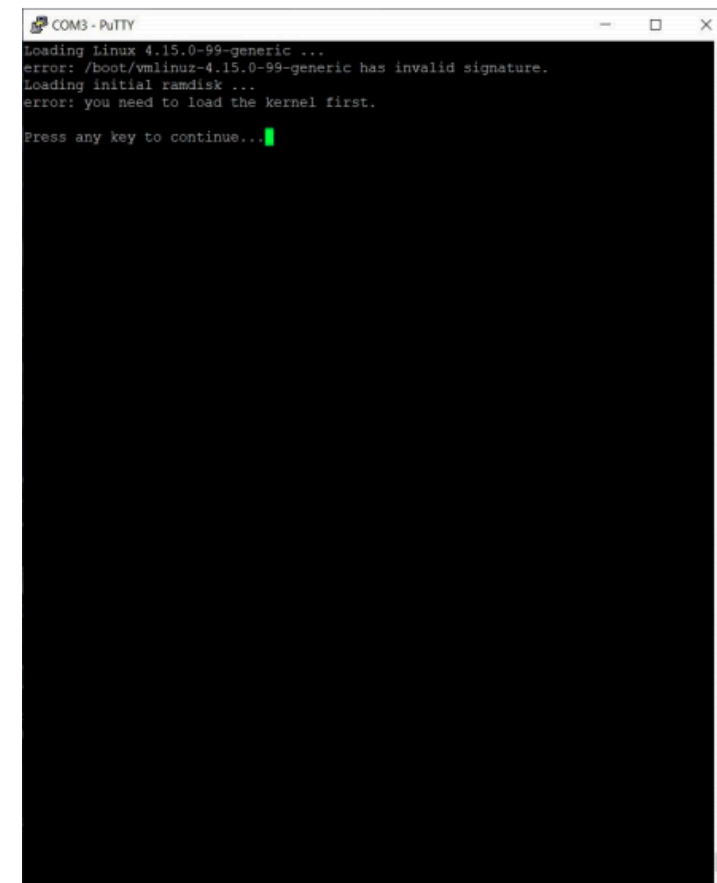
Работа 3. TPM 2.0 и measured boot

- TPM измеряет каждый этап загрузки в регистры PCR (цепочка хешей)
- `systemd-cryptenroll --tpm2-device=auto` — ключ LUKS «опечатан» в PCR
- Изменилось состояние загрузки (прошивка, загрузчик, ядро) → ключ не выдан
- Эмуляция TPM: VirtualBox 7, VMware, QEMU (swtpm)



Работа 4. UEFI Secure Boot

- Цепочка доверия: ключи платформы (PK/KEK/db)
→ shim → GRUB → ядро
- Неподписанное ядро или модуль не загружаются (kernel lockdown)
- Debian из коробки предоставляет подписанные shim, GRUB и ядро
- Проверка: `mokutil --sb-state` , `sbverify --list /boot/vmlinuz-...`

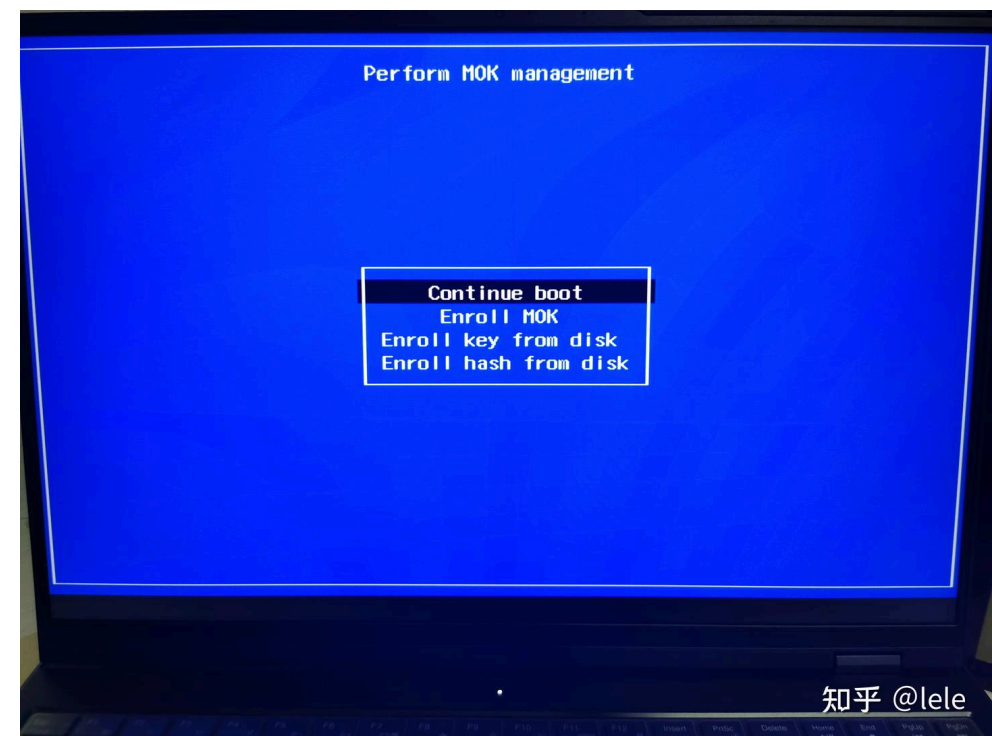


A screenshot of a terminal window titled 'COM3 - PuTTY'. The terminal displays the following text: 'Loading Linux 4.15.0-99-generic ...', 'error: /boot/vmlinuz-4.15.0-99-generic has invalid signature.', 'Loading initial ramdisk ...', 'error: you need to load the kernel first.', and 'Press any key to continue...' followed by a green cursor. The terminal background is black, and the text is white.

Работа 4. MOK: собственный ключ

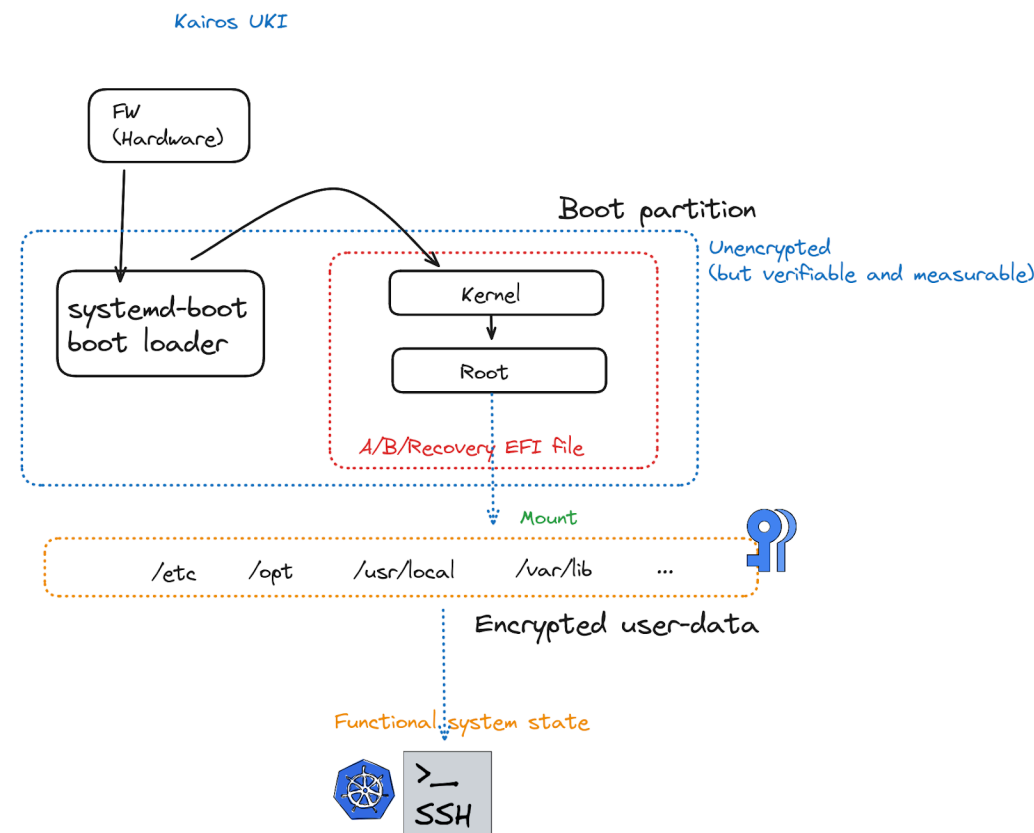
```
openssl req -new -x509 -newkey rsa:2048 -keyout MOK.priv \
-outform DER -out MOK.der -nodes -days 36500 -subj "/CN=Student MOK/"
sudo /lib/modules/$(uname -r)/build/scripts/sign-file \
sha256 MOK.priv MOK.der hello.ko
sudo mokutil --import MOK.der # регистрация ключа при загрузке
```

- При перезагрузке: меню **MOK management** → **Enroll MOK** и пароль
- После регистрации собственные модули «доверенные» для ядра



Работа 5. UKI: единый подписанный образ

- UKI = ядро + initrd + cmdline в одном `.efi`-файле (PE-образ)
- Сборка: `ukify` / `dracut` ; загрузка: `systemd-boot` или напрямую UEFI
- Командная строка внутри подписанного образа — её нельзя править из меню
- Связка Secure Boot + UKI + TPM = неизменяемая доверенная загрузка



Итоги: какой эшелон от чего защищает

Эшелон	Средства (Debian 13)	Закрываемая угроза
Прошивка	UEFI Secure Boot, MOK	неподписанные загрузчик/ядро/ модули
Загрузчик	пароль GRUB (PBKDF2)	правка параметров, <code>init=/bin/bash</code>
Диск	LUKS2 + initramfs	кража диска / образа VM
Измерение	TPM 2.0, PCR, <code>systemd-cryptenroll</code>	«evil maid», подмена компонентов
Целостность	UKI, подписанные <code>.efi</code>	подмена ядра, initrd, cmdline

Материалы и порядок выполнения

- **Лабораторная работа включает:** Работа 1 (GRUB2) и Работа 4 (Secure Boot + MOK)
- GRUB Manual: gnu.org/software/grub/manual/grub
- Debian Wiki: wiki.debian.org/SecureBoot
- Документация ядра: Module signatures, Kernel Lockdown (docs.kernel.org)
- systemd: `man systemd-cryptenroll`, `man ukify`, `man systemd-measure`
- Иллюстрации: ByteByteGo, Eclypsium, fdmux.dev, Spectro Cloud, материалы сообществ